

Table.1: Fixes/improvements done in IVXV 1.9.10 EP2024

Risk	Deployed Solution	Remaining Issues	GiHub File	Corresponding Academic Research
Invalid votes	<u>2024:</u> Decrypted in a separate file with ZKPs of correct decryption	-Files are viewable by auditors only (complaints)	Embedded in [25] <i>DecryptTool.java</i>	Tallinn Univ. Ms. thesis [22] (Jun 2024)
	<u>2025:</u> Deployed <i>Range Proofs</i> to prevent invalid votes from entering the votes list.	-Invalid votes (3 due to format in 2025 test voting, although 0 in real elections) can still enter the system through private voting applications.	Added in the server-side part of the voting application [15] and in the verification code	The thesis in [22] and the scientific report in [24]
The Voting/Voter Application (VA)	<u>2024:</u> Authenticated through a fingerprint [37]	- Complicated and involves many steps for regular users		Jan Willemson, E-Vote-ID 2025 paper [9]
	<u>2025:</u> Publishing the server-side code of the voting application [15]	-Assumes trust in the official VA (client- side part) -Ghost Click attack if compromised e-ID PIN codes + card available on PC long enough [30,32] -Problems remain for non-verifying and absent voters (see Table.2 for attacks even for verifying voters)	[15] https://github.com/valimised/ivxv/blob/publicshed/voting/service/voting/main.go	
Ballot Processor (BP) manipulation	<u>2024:</u> Consistency checks on SHA256 hashes of totals and subtotals.	- <i>Offline</i> checks; i.e., count based validation depends on trusting the Vote Collector (VC) and Registration Service (RS) to not collude before the list enters the BP.	A new file [28] <i>IntegrityTool.java</i>	Tallinn Univ. researchers [29] (Dec 2024)
Timing attacks	<u>2024:</u> Checking <i>Session ID</i> and <i>Timestamps</i> difference, which are generated by <i>PKIX</i> protocol	-Cannot detect fast attacks ([33]) that can manage to work in the duration of one session (like <i>Pereira attack</i> [30]); could be solved by enforcing a time gap between multiple votes in addition (this paper).	A new file [36] <i>Client.go</i>	An extension, [33], to a Luxemburg Univ. PhD on formal verification of i-voting systems, applied to IVXV (Jun 2024)

Table A2. Remaining vulnerabilities/risks in IVXV 1.10 E2025 and suggested solutions

Vulnerability	Risks/threats	Concerns/Complaints about the issue	Suggested Solutions	Proposed by
The Voting Application (VA)	-Pereira attack [30] -Copy attack on Privacy [33] -Large-scale vote copying [51, this paper] -Variety of malicious VA risks -Extra risks for smart phone VA [53] -Injecting votes through voting trojan horses embedded in other purpose malicious apps; risky even for verifying and authenticating voters (this paper).	-Cybernetica supervised PhD [19/sec.5-6] -Olivier Pereira [30] -OSCE/ODHIR 2023 report [2] -Cyber Security Committee report [53] -Many other researchers including the author of this paper.	Using a <i>microcontroller</i> voting device	Tallinn Univ. PhD [19] (2022)
			-Publishing the VA code (change the law) -Batched easier checking of <i>file hash</i> , [52] -Assigning a <i>signature key</i> for VA and allowing <i>optional registering of other VAs</i> but after scanning the code for malicious activities (more robust but require flexibility and cooperation from authorities to not reject unobjectively). -Activate an <i>SMS ack</i> with every election transaction on election days, but could be delayed as discussed in [30] or discovered by vote coercers [9,34,35]. -Let the Ballot Processor, section 4.2, check and <i>alarm the existence of equal encryptions</i> even from different voters. -If the system insists on keeping the VA situation as is, using <i>a separate ID card for elections</i> (suggested in [35] for another reason) can protect from the possibility of casting votes through apps with <i>trojan horse</i> that take the voter’s signature claiming other purposes. Another solution is to <i>add a meta data field</i> that allows IVXV to check <i>the application category</i> .	Poster [51] in E-Vote-ID 2025, and this paper
Insiders’ Trust	VC and RS are trusted to not collude; their collusion may result in: -privacy attacks [26,33] -different possible manipulations of the ballots list before entering the ballot processor	-Estonian parties and i-voting opposing communities in general [1,2, 21] -Detected by automated formal verification tools in [33,46].	-Adding a <i>NIZKP</i> to each vote.	[26] (2022)
			-Performing different <i>consistency check ZK queries</i> , and <i>RLAs</i> , between ballots list and other services recording digital transactions like <i>myID</i> [31]. -Using <i>Verkle Trees (Vector Commitments)</i> based on KZG commitments to cryptographically prove votes integrity and counters; requires universal trusted setup (integrity risk).	E-Vote-ID 2025 poster [43]
			-Using <i>Vector Commitments</i> based on Pedersen commitments to cryptographically prove vote correctness; no trusted setup + faster + aligns with used Range Proofs.	E-Vote-ID 2025 paper [44]
Integrity vs. Coercion	Services recording digital transactions like <i>myID</i> [31] can be used by vote’ coercers to prove last vote.	-Observer’s E-Vote-ID poster in 2023 [34]	-Making election transactions secret or obfuscated -Using a special ID card for e-voting that doesn’t allow such integrity checks on its transactions.	E-Vote-ID 2025 paper [35]
Software Auditing	The risk of not detecting programming errors, security vulnerabilities, back doors, covert channels, side channels,... problems beyond the happy path of execution	-The supreme court complaint in [38] -The Academy of Sciences report, [53], when weighing the pros & cons of open sourcing the VA. -The paper in [48].	-Publish the voting application (VA) as an open source.	The report [53]
			-Publish the new version long enough to be analyzed before the election.	(complainer + court [38]) + law [18]
			Auditing the code as a structured software-testing task grounded in mission & safety-critical principles (DO-178C)	Research article [48]
Absent Voters	-If their devices and credentials are compromised as <i>botnets</i> or through any dark web market, votes can be injected on their behalf. -This could happen through trojan horse apps too.	-Falls under “ <i>unavoidable risks that can’t be performed on large-scale</i> ” by [19/ref.166] as it will cause “ <i>observable anomalies</i> ” -Falls under (<i>corrupted voter device+ corrupted communication network</i>) category detected in [33]	<u>Only safeguards</u> , no complete protection: -Activate an <i>SMS ack</i> with every election transaction on election days; could be delayed as discussed in [30] or discovered by vote coercers [9,34,35]. -use a <i>NIZKP</i> that supports <i>Non-inclusion proofs</i> , and check <i>RLA</i> samples; voters could lie to falsify elections. -Allow a “ <i>reject all</i> ” choice to incentivize even boycotters to vote	This paper
Poll Station manipulation	A malicious poll station worker could alter vote IDs (keeping the number consistent with the ballot box count) to delete the e-votes of some (by faking a booth vote) and double the votes of others (by giving them the chance to add another online vote)	To our knowledge, the Estonian Cyber Security Academy report, [53], was the first to identify the vulnerability as a “ <i>noteworthy</i> ” threat.	-Notify the voter through an email or any other notification channel of a poll station vote; could be deliberately delayed as [30] worries.	Cyber Security Academy report [53]
			-Check for anomalies like an e-vote with time stamp larger than the timing of the corresponding poll station vote. -Take a random sample of poll station cancelled votes and contact them to check the truth before deleting; then apply <i>RLA</i> techniques to decide on the result.	This paper -Anomalies as fault scenarios in [48]
Quantum Computing	-Breaks existing cryptography -Privacy Risks (<i>HNDL</i>)	- Warned about <i>HNDL</i> in earlier versions of this paper (2024) -Cyber Security Committee report [53] (2025), could put an end to e-voting in Estonia if not mitigated	-Prevent data leakage -Defining measures and advising techniques to make sure of the complete destruction of all election data -Prepare carefully, without rush, for the transition to post quantum cryptography (<i>PQC</i>)	Cyber Security Academy report [53]
			-Lengthening hashes and message digests to be <i>PQ</i> -Adding another layer of <i>PQ AES-GCM encryption</i>	This paper
AI	-Leakage of voter’s vote -Discover exploits -Organize a sophisticated attack	-The vote leakage in the [53] report (considered a less significant threat). -Exploits & attacks (this paper).	None yet	